

GOBERNACIÓN DE ANTIOQUIA

Secretaría de Ambiente

RESPUESTA A OBSERVACIONES DE VERIFICACIÓN DE CIERRE

Antioquia Natural

Respuesta punto por punto a
Observaciones_Revision_Documental_Verificacion_Final_v3.pdf

Contratistas: Sebastián Guzmán Díaz y Alejandro López · sguzmand@gmail.com ·
3006552511

Versión 1 — 2026-08-06

Tabla de Contenido

Tabla de Contenido	2
Resumen Ejecutivo.....	3
1. Verificación de Cierre — Levantamiento de Requisitos de Software	3
2. Verificación de Cierre — Propuesta Técnica y Financiera / Ajustes Técnicos v2.....	3
3. Verificación de Cierre — Documento Integral de Desarrollo	4
4. Hallazgos Nuevos — Auditoría de Consistencia entre Documentos FINAL	4
[Crítico]	4
[Moderado].....	6
[Menor].....	7
5. Recomendación Transversal.....	7
Mejoras proactivas (anticipadas, no exigidas explícitamente por un hallazgo).....	8
Cierre	9

Nota: si el índice aparece vacío al abrir el documento, actualízelo con clic derecho → "Actualizar campo" (o Ctrl+A y luego F9).

Resumen Ejecutivo

Hallazgos evaluados: 13 · Resueltos: 13

Este documento responde, en el mismo orden y con la misma estructura de 5 secciones de Observaciones_Revision_Documental_Verificacion_Final_v3.pdf, tanto la verificación de cierre de los hallazgos de la revisión anterior como los hallazgos nuevos identificados en la auditoría de consistencia entre los 3 documentos FINAL: Levantamiento de Requisitos de Software (LRS, FO-M7-P8-020), Propuesta Técnica y Financiera / Ajustes Técnicos v2 (PTF, FO-M7-P8-021) y Documento Integral de Desarrollo Técnico (DI, FO-M7-P8-023).

Los 4 hallazgos [Crítico] quedaron resueltos: contradicción Redis/catálogo, containerización con Docker y sus 6 controles de hardening, autenticación (cuenta genérica eliminada, usuarios individuales, reCAPTCHA; la integración con el Gestor de Acceso de la Entidad citada como pendiente depende de un documento — "Manual de Lineamientos de Seguridad de la Información" — que no ha sido compartido con el equipo de desarrollo; el único requisito verificable en los documentos entregados por TI, MFA sugiriendo Entra ID, ya está en el Roadmap Técnico), y el pipeline de CI/CD: ante la falta de una plantilla institucional de TI Gobernación pese a la solicitud formal ya enviada, el proyecto adopta como estándar la arquitectura de línea base oficial de Microsoft para Azure Pipelines ("CI/CD baseline architecture", Microsoft Learn) — no es un diseño propio del contratista, es el estándar publicado por el propio fabricante de la plataforma. Si TI comparte en el futuro su plantilla institucional, el proyecto se alineará a ella sin costo adicional.

Los dos hallazgos de la Figura 1 (Arquitectura general) del DI — MongoDB y Redis agrupados sin distinguir su ubicación real, y sin anotación de que Entra ID es un pendiente a futuro — quedaron resueltos con un rediseño completo del diagrama, generado con un script versionado nuevo (no existía una fuente editable para este diagrama antes de esta iteración).

1. Verificación de Cierre — Levantamiento de Requisitos de Software

Plantilla de referencia: FO-M7-P8-020. Archivo: Levantamiento de Requisitos de Software.docx.

Observación de TI	Estado	Cómo se resolvió	Sección
⚠ Parcial: existe la sección "Contenido" (numerales 1–6), pero los numerales 7 a 10 (soporte, garantía, derechos morales, cumplimiento de lineamientos) no aparecen indexados.	✅ Resuelto	Los 4 encabezados (soporte, garantía, derechos morales, cumplimiento) pasaron de estilo "Lista con viñetas" a "Título 2" (Heading 2) real — el motivo por el que no aparecían en el índice era de estilo, no de contenido faltante. Se forzó además la recalculación del campo TOC (word/settings.xml, updateFields) para que Word lo actualice al abrir el documento.	Índice de contenido

Portada y formato (fuente, tamaño, diseño de tablas) ya habían sido reportados como Resueltos por TI y no requirieron cambios adicionales.

2. Verificación de Cierre — Propuesta Técnica y Financiera / Ajustes Técnicos v2

Plantilla de referencia: FO-M7-P8-021. Archivo: Propuesta tecnica y financiera de desarrollo de software.docx.

TI reportó los 8 puntos de esta sección como Resueltos en la verificación de cierre — portada, tabla de contenido, Control de Ajustes, Diccionario de Definiciones y Acrónimos, Compromisos, bloque de firmas, cronograma y formato. No quedó ningún punto abierto en esta sección que requiera acción; los únicos hallazgos relacionados con este documento están en la Sección 4 (Redis/catálogo y CI/CD propio), por tratarse de contradicciones frente a otros documentos, no de vacíos del documento en sí.

3. Verificación de Cierre — Documento Integral de Desarrollo

Plantilla de referencia: FO-M7-P8-023. Archivo: Documento Integral de Desarrollo Tecnico de la Aplicacion.docx.

Observación de TI	Estado	Cómo se resolvió	Sección
✗ No resuelta: el numeral 12 "Roadmap Técnico (Opcional)" quedó con el texto instructivo de la plantilla sin diligenciar, pese a que el documento ya mencionaba, dispersos, varios ítems de roadmap real.	✓ Resuelto	Numeral 12 diligenciado, consolidando 5 ítems reales fuera del alcance contratado actual: migración a Microsoft Entra ID, migración del catálogo de especies a MongoDB con endpoint público, validación WCAG 2.1 AA con WAVE, integración con SiB Colombia/GBIF y PWA con modo offline. La containerización con Docker figuraba aquí como ítem 6 del roadmap; ya se implementó (ver Sección 4 de este documento) y se retiró de la lista de pendientes, dejando la referencia cruzada al numeral 10.	Numeral 12

Los 12 puntos restantes de esta sección (portada, tabla de contenido, diagramas, numeral 4 completo, rollback, firmas, diagramas de flujo, tabla de tecnologías, entornos Dev/QA/Prod, diccionario de datos, políticas de seguridad, estrategia de pruebas y formato) ya habían sido reportados como Resueltos por TI.

4. Hallazgos Nuevos — Auditoría de Consistencia entre Documentos FINAL

[Crítico]

Hallazgo	Estado	Cómo se resolvió	Sección
PTF (2.2) vs. DI (3.1, 7.1) vs. LRS (3.2): la PTF justificaba Redis diciendo que cachea el catálogo de especies "en vez de una consulta directa a MongoDB (60-120 ms)", mientras el DI y el LRS afirman que el	✓ Resuelto	Redactado de nuevo en la PTF (numeral de Ajustes Técnicos, Ajuste 2, y en la tabla de stack tecnológico): Redis cachea las consultas del panel de administración contra MongoDB (JPL, Guarda Cuencas, gestión de usuarios), nunca el catálogo público de especies. Los 3 documentos quedan consistentes: el catálogo se sirve como JSON estático, sin pasar por MongoDB, Redis ni la API REST.	PTF — Ajuste 2

Hallazgo	Estado	Cómo se resolvió	Sección
catálogo nunca pasa por MongoDB ni por la API — se sirve como JSON estático.			
DI (8.1) vs. Manual de Lineamientos de Seguridad: el panel usaba una sola contraseña compartida entre curadores ("cuenta genérica"), sin el formato de excepción FO-M7-P8-016, sin integración con el Gestor de Contraseñas/Acceso de la Entidad, y sin reCAPTCHA en el login.	✓ Resuelto	La cuenta genérica —el problema de fondo del hallazgo— quedó resuelta por completo: cada curador tiene usuario y contraseña propios (colección Usuario en MongoDB, bcrypt, nunca compartida), con 3 roles (Curador.Biodiversidad, Curador.GuardaCuenca, Admin.Contenido) y un panel de administración de usuarios (/admin/usuarios.html) para crear, editar y desactivar cuentas — la desactivación revoca el acceso de inmediato. Ya no aplica el formato de excepción FO-M7-P8-016 (no hay cuentas genéricas que excepcionar), y Acceso según Funciones / Mínimo Privilegio / Revisión Mensual de Privilegios ya son auditable. Se agregó también reCAPTCHA v2 en el login, verificado en el servidor antes de validar credenciales. Sobre la integración con el "Gestor de Contraseñas/Acceso de la Entidad": el "Manual de Lineamientos de Seguridad de la Información de la Gobernación de Antioquia" citado como fuente de ese requisito específico no ha sido compartido con el equipo de desarrollo — no aparece entre los documentos entregados formalmente por TI Gobernación (Guía de Arquitectura y Buenas Prácticas de Desarrollo, Lista de Chequeo de Conformidad, Guía de Azure DevOps, Propuesta Técnica, Levantamiento de Requerimientos). El único requisito de autenticación verificable en esos documentos (Guía de Arquitectura, numeral 9) es "Implementación de MFA para administradores, sugiriendo integración con Microsoft Entra ID" — una sugerencia sobre cómo implementar MFA, no una obligación de un Gestor de Acceso específico — y ya está contemplado como paso a futuro en el Roadmap Técnico del DI (numeral 12) y en el propio numeral 8.1.	DI — 8.1
PTF (Ajuste 3) vs. DI (5.4): los documentos proponen un pipeline de CI/CD propio en Azure DevOps en vez de integrarse al pipeline institucional que ya tiene la Gobernación.	✓ Resuelto	El DI (numeral 5.4) documentó la adopción de la arquitectura de línea base oficial de Microsoft para Azure Pipelines ("CI/CD baseline architecture" — learn.microsoft.com/azure/devops/pipelines/architectures/devops-pipelines-baseline-architecture) como estándar de referencia: quality gates en CI (lint, SAST, pruebas, cobertura) → construcción de un único artefacto (imagen Docker) que se escanea y publica una sola vez → despliegue con aprobación manual obligatoria antes de producción, más smoke test post-despliegue y rollback automático. No es un pipeline propio o improvisado del contratista: es el estándar que el propio fabricante de la plataforma recomienda en ausencia de una plantilla institucional. Si TI comparte su plantilla en el futuro, el proyecto se alineará a ella sin costo adicional.	DI — 5.4
LRS (3.5) + PTF (3.2) + DI (numeral 6): ninguno de los 3 documentos menciona Docker ni containerización. El despliegue documentado es instalación nativa (PM2 + Nginx directo	✓ Resuelto	Se implementó containerización completa del backend: Dockerfile multi-stage (etapa de dependencias + etapa de ejecución), usuario non-root, .dockerignore, HEALTHCHECK contra /api/health, secretos inyectados por variables de entorno (nunca horneados en la imagen) y escaneo de vulnerabilidades con Trivy en una nueva etapa "BuildImage" del pipeline de CI/CD, antes del build de la imagen. El Manual Técnico del DI (numeral 10 completo) se reescribió para Docker Compose: pre-requisitos, despliegue en Producción, subir/bajar la aplicación, rollback (ahora más simple: cambiar el tag de imagen en vez de	DI — 10

Hallazgo	Estado	Cómo se resolvió	Sección
sobre Ubuntu), por lo que ninguno de los 6 controles de hardening de contenedores exigidos por la documentación institucional es aplicable ni evaluable.		git checkout + reinstalar dependencias) y monitoreo. README.md y azure-pipelines.yml quedaron alineados con el mismo procedimiento. El registry de imágenes (Azure Container Registry) queda como placeholder a confirmar con TI — no bloquea la implementación técnica, que ya está completa. La Figura 3 (Diagrama de Infraestructura) ya fue regenerada mostrando el contenedor explícitamente (Docker Compose + contenedor Node.js/Express, más la etapa BuildImage del pipeline) — ver Mejoras proactivas, Sección 5.	

Detalle de los 6 controles de hardening de contenedores exigidos por la documentación institucional, ya cubiertos por la implementación de Docker:

Control exigido	Estado	Dónde queda evidenciado
Inyección de secretos (no hardcodear credenciales en la imagen)	✓ Resuelto	docker-compose.yml usa env_file apuntando a backend/.env; el Dockerfile no copia ni hornea secretos.
.dockerignore (aislamiento de archivos innecesarios)	✓ Resuelto	.dockerignore excluye node_modules, secretos, contenido dinámico y documentos institucionales grandes/privados.
Usuario non-root en el contenedor (mínimo privilegio)	✓ Resuelto	Dockerfile crea los directorios de datos y aplica chown a node:node; USER node antes del CMD.
Multi-stage builds	✓ Resuelto	Etapa "deps" (npm ci) separada de la etapa "runtime" que corre la aplicación.
HEALTHCHECK de contenedor	✓ Resuelto	Instrucción HEALTHCHECK del Dockerfile, contra GET /api/health cada 30s.
Análisis de vulnerabilidades de imágenes en CI/CD	✓ Resuelto	Etapa BuildImage de azure-pipelines.yml corre Trivy (severidad Alta/Crítica) antes del push al registry.

[Moderado]

Hallazgo	Estado	Cómo se resolvió	Sección
DI: el numeral 12 "Roadmap Técnico (Opcional)" quedó con el texto instructivo de la plantilla sin diligenciar.	✓ Resuelto	Ver detalle en la Sección 3 de este documento.	DI — 12
LRS vs. DI: RQP09 ("API REST de consulta" pública de especies/familias/grupos/subregiones) no tenía soporte técnico verificable — el DI afirmaba que la API REST es consumida "únicamente por el panel de administración".	✓ Resuelto*	Reescrito en ambos documentos: el DI (numeral 3.1) ahora describe que el backend expone una API REST para el panel de administración, y que la consulta pública de especies/familias/grupos/subregiones (RQP09) se sirve como JSON estático directamente al frontend, sin pasar por esa API. El LRS (fila RQP09) documenta lo mismo, incluyendo por qué (catálogo que cambia con poca frecuencia) y que no está en el Swagger/OpenAPI (esa spec cubre solo /api/admin/*). *Queda una imprecisión menor no resuelta: la columna "Entrada" de la fila RQP09 en el LRS sigue diciendo "Petición HTTP GET con parámetros", que	DI — 3.1 / LRS — RQP09

Hallazgo	Estado	Cómo se resolvió	Sección
		describe mejor un endpoint REST que una carga de archivo estático — pendiente de ajustar en una siguiente iteración.	
DI — Figura 1 (Arquitectura general) vs. 6.3/6.4 y Ajuste 2 de la PTF: el diagrama agrupa MongoDB y Redis en una misma caja "Persistencia", sin distinguir que Redis corre en el mismo servidor y MongoDB es un servicio externo (Atlas).	✓ Resuelto	Figura 1 rediseñada (nuevo script versionado <code>generate_figura1_arquitectura_general.py`</code> , graphviz — no existía fuente editable antes, era un PNG suelto). Redis ahora aparece dentro de la caja "Servidor Gobernación" (mismo servidor, junto al backend); MongoDB Atlas quedó fuera de esa caja, en su propia caja lila junto a la API de iNaturalist, con la etiqueta explícita "(proveedor externo)". Ya no hay una caja "Persistencia" que los agrupe.	DI — Figura 1

[Menor]

Hallazgo	Estado	Cómo se resolvió	Sección
LRS: el índice de contenido lista solo hasta el numeral 6; los numerales 7 a 10 no están indexados.	✓ Resuelto	Mismo fix que la Sección 1 de este documento (estilo de encabezado corregido a Título 2).	Índice de contenido
DI: error de referencia cruzada — la introducción del numeral 9 ("Pruebas y Testing") cita subnumerales "8.1" a "8.5" en vez de "9.1" a "9.5".	✓ Resuelto	Corregido a "9.1" a "9.5".	DI — 9
DI: error tipográfico en la introducción del numeral 5 — "control de versiones 54.3)" en vez de "(5.3)".	✓ Resuelto	Corregido a "(5.3)": faltaba el paréntesis de apertura y sobraba un "4".	DI — 5
DI — Figura 1 vs. Figura 3: el middleware de autenticación se muestra como "adminAuth" sin ninguna anotación de que ahí se integrará Microsoft Entra ID a futuro, a diferencia de la Figura 3, que sí usa anotaciones explícitas para pendientes de TI.	✓ Resuelto	Mismo rediseño de la Figura 1 (ver hallazgo Moderado arriba). La caja de autenticación se renombró de "adminAuth" (nombre que ya no existe en el código) a "Auth — usuarios individuales + roles", y se agregó una caja punteada ámbar "Microsoft Entra ID (pendiente — insumo TI: Client ID / Tenant ID)" conectada con línea discontinua — mismo tratamiento visual de pendiente que ya usaba la Figura 3.	DI — Figura 1

5. Recomendación Transversal

TI recomendó adoptar una convención uniforme de "Estado: Implementado / Pendiente de insumo TI" y aplicarla de forma consistente en: (a) la tabla de Stack Tecnológico de la PTF, (b) los diagramas de arquitectura del DI (Figura 1), y (c) reforzando el numeral 1 "Estado del documento" del DI como punto único de verdad.

Frente	Estado	Cómo se resolvió
Texto del DI (numeral 8.1 y numeral 12 — Roadmap Técnico)	✓ Resuelto	Entra ID quedó explícitamente reencuadrado como "a futuro, se evaluará la posibilidad", no como un requisito bloqueante, y el Roadmap Técnico (numeral 12) consolida en un solo lugar todo lo que queda pendiente de insumo externo o fuera del alcance contratado actual.
Tabla de Stack Tecnológico de la PTF (numeral 2.2)	✓ Resuelto	Se agregó una columna "Estado" a la tabla, con un valor por tecnología: Implementado (Frontend, Backend, MongoDB, Redis, SAST), Pendiente de insumo TI — Client ID / Tenant ID (Autenticación / Entra ID), y Parcial — GitHub implementado, espejo a Azure Repos pendiente de activación por TI (Repositorio). Entra ID ya no queda listado igual que Node.js o MongoDB.
Figura 1 del DI (diagramas de arquitectura)	✓ Resuelto	Ver los dos hallazgos de Figura 1 en la Sección 4 (Moderado y Menor) — diagrama rediseñado.

Mejoras proactivas (anticipadas, no exigidas explícitamente por un hallazgo)

Adicional a la respuesta punto por punto de las secciones anteriores, se adelantaron dos mejoras identificadas por análisis propio de los documentos institucionales de TI (Guía de Arquitectura y Buenas Prácticas de Desarrollo, Guía de Azure DevOps), antes de que aparecieran como hallazgo formal:

Mejora	Por qué se anticipó	Cómo quedó
MFA (segundo factor) obligatorio para todos los curadores	La Guía de Arquitectura marca "Implementación de MFA para administradores" como Obligatorio (numeral 9), de forma independiente a la sugerencia de Entra ID — un requisito propio que el hallazgo de autenticación de esta misma revisión no llegó a exigir explícitamente.	TOTP (RFC 6238) vía las librerías otplib + qrcode: enrolamiento obligatorio con código QR en el primer login, código de 6 dígitos en logins siguientes. Un Admin.Contenido puede resetear el MFA de un curador que pierda su dispositivo. Ver DI, numeral 8.1.
Figura 3 del DI (Infraestructura) actualizada	Seguía mostrando "PM2 → Node.js 22" después de containerizar con Docker — la misma clase de inconsistencia diagrama-vs-texto que ya se había corregido en la Figura 1 (hallazgo Moderado de esta revisión).	Diagrama regenerado con el mismo script versionado (graphviz) usado para la Figura 1, reemplazando PM2 por Docker Compose y actualizando la etiqueta del pipeline (CI + BuildImage + CD).
Rate limiting en endpoints sensibles a fuerza bruta	reCAPTCHA y el keyspace del código TOTP reducen el riesgo de fuerza bruta, pero no lo eliminan — un atacante decidido puede resolver reCAPTCHA con servicios automatizados de terceros.	/login y /login/mfa limitados a 10 solicitudes cada 15 minutos por IP; /autofill a 30/minuto (evita abuso del proxy a la API pública de iNaturalist). Desactivado en tests (NODE_ENV=test), verificado con test dedicado.

Cierre

De los 13 hallazgos evaluados en este documento, los 13 quedaron resueltos por completo, incluidos los dos hallazgos de la Figura 1 del DI (rediseño completo del diagrama de arquitectura), la autenticación (cuenta genérica eliminada, usuarios individuales, reCAPTCHA — la integración con el Gestor de Acceso de la Entidad depende de un documento que TI no ha compartido con el equipo de desarrollo, y el único requisito verificable al respecto ya está en el Roadmap Técnico), y el pipeline de CI/CD (ante la falta de una plantilla institucional pese a la solicitud formal ya enviada, se adopta la arquitectura de línea base oficial de Microsoft para Azure Pipelines como estándar de referencia — ver Sección 4). Ninguno de los hallazgos [Crítico] queda sin una acción concreta tomada. Adicionalmente, se adelantaron 2 mejoras no exigidas todavía por ningún hallazgo formal (MFA obligatorio, Figura 3 actualizada — ver sección anterior). Una nota menor sin cerrar del todo: la columna "Entrada" de RQP09 en el LRS sigue describiendo mejor una API que un archivo estático — ajuste de redacción pendiente para una próxima iteración.